

Security+ 2.5 · Segmentation & Access Control

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.5** —
Segmentation & Access Control (6:06) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Network segmentation isolates systems using VLANs, subnets, or DMZs (screened subnets) to prevent lateral movement. Access Control Lists (ACLs) define what traffic can enter or exit a resource. An allowlist (default deny) is more secure than a denylist (default allow) because it only permits known-good traffic. Microsegmentation provides fine-grained isolation, aligning with Zero Trust principles.

High-Yield Core Concepts Tested on Exam

- DMZ (screened subnet): a buffer zone between the internet and internal network for public-facing services.
- Allowlist (deny-by-default) is more secure than denylist (allow-by-default).
- Microsegmentation: isolates individual workloads, enforcing Zero Trust.
- ACL: defines what traffic is permitted to or from a resource.
- Segmentation limits lateral movement in case of compromise.

Exam Tips & Classic Scenarios

- 'default deny, permit only known' = allowlist.
- 'zone between internet and internal network' = DMZ/screened subnet.
- 'isolate each workload' = microsegmentation.

Typical Exam Scenario: A public web server resides in a subnet that can communicate with the database, but the internal network cannot reach it directly. This is a DMZ (screened subnet) design, which limits exposure and lateral movement.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.5 — Segmentation & Access Control)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. An isolated subnet that exposes public servers (web/email) while protecting the internal network is a:

- A)** Voice VLAN
- B)** DMZ (screened subnet)
- C)** VPN
- D)** Intranet

2. Using MULTIPLE layers of defense (firewall + antivirus + MFA + training) so as not to depend on just one is:

- A) Zero Trust**
- B) Defense in depth**
- C) Fail-open**
- D) Security through obscurity**

3. A scammer calls pretending to be IT support and creates urgency for you to give your password. The social engineering principle exploited is:

- A) Scarcity**
- B) Authority + urgency**
- C) Social proof**
- D) Reciprocity**

4. Corporate scenario (Segmentation & Access Control): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.5), an analyst evaluates the following technical requirement: 'DMZ: zone between internet and internal network — public services reside there'. What is the best recommendation or applicable control classification?

- A) Temporarily disable audit logs to accelerate system throughput**
- B) Replace preventive technical controls with informal terms of adherence**
- C) Allow shared access among administrators with generic credentials**
- D) Implement the corresponding solution: DMZ: zone between internet and internal network — public services reside there**

5. Corporate scenario (Segmentation & Access Control): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.5), an analyst evaluates the following technical requirement: 'Allowlist (deny-by-default) is MORE SECURE than denylist.' What is the best recommendation or applicable control classification?

- A) Temporarily disable audit logs to accelerate system throughput**
- B) Replace preventive technical controls with informal terms of adherence**
- C) Implement the corresponding solution: Allowlist (deny-by-default) is MORE SECURE than denylist...**
- D) Allow shared access among administrators using generic credentials**

6. Corporate scenario (Segmentation & Access Control): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.5), an analyst evaluates the following technical requirement: 'Microsegmentation: each workload isolated — Zero Trust applied'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: Microsegmentation: each workload isolated — Zero Trust applied...

7. Corporate scenario (Segmentation & Access Control): During a security review and compliance audit aligned with the CompTIA Security+ (SY0-701, Section 2.5) exam, an analyst evaluates the following technical requirement: 'default deny, permit only known' = allowlist'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'default deny, permit only known' = allowlist.
- D)** Allow shared access among administrators with generic credentials

8. Corporate scenario (Segmentation & Access Control): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.5), an analyst evaluates the following technical requirement: 'zone between internet and internal network' = DMZ/screened subnet. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'zone between internet and internal network' = DMZ/screened subnet...
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Segmentation & Access Control): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.5), an analyst evaluates the following technical requirement: 'Scenario: 'public web server resides in a subnet that can talk to the DB but the internal network cannot reach it' = DMZ/screened subnet.'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Scenario: 'public web server resides in a subnet that can talk to the DB but...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

10. Corporate scenario (Segmentation & Access Control): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.5), an analyst evaluates the following technical requirement: 'DMZ: zone between the internet and internal network — public services live there'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: DMZ: zone between the internet and internal network — public services live there...
- D)** Allow shared access among administrators using generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — DMZ (screened subnet).

✓ **Why it's correct:** The correct answer is 'DMZ (screened subnet)'. A DMZ (Demilitarized Zone), also called a screened subnet, is an isolated network segment that sits between the trusted internal network and the untrusted external network (such as the Internet). It hosts public-facing servers, such as web, email, DNS, and FTP, which need to be accessible externally. The goal is that if one of these servers is compromised, the attacker does not have direct access to the internal network, because firewalls control traffic between the DMZ and the internal network. CompTIA Security+ SY0-701, in the Architecture and Design domain (2.2), describes the DMZ as a security zone for exposing public services in a controlled manner. The question describes exactly this function: an isolated subnet that exposes public servers while protecting the internal network.

✗ **Why the others are wrong:**

- *Voice VLAN:* A voice VLAN is a virtual local area network dedicated to VoIP (Voice over IP) traffic, separating it from data to ensure quality of service (QoS) and security. It is not designed to expose public servers to the Internet; on the contrary, it isolates voice traffic. It does not provide the isolation between internal and external networks that a DMZ provides. Therefore, it does not meet the requirement of protecting the internal network while exposing public services.
- *VPN:* A VPN (Virtual Private Network) is a technology that creates an encrypted tunnel to transmit data securely over untrusted networks, enabling remote access or branch interconnection. Although it improves communication security, it is not an isolated subnet for hosting public servers. A VPN can be used to access the DMZ, but it does not replace the DMZ. The question asks for a network zone that exposes public servers, which is not the primary function of a VPN.
- *Intranet:* An intranet is a private internal network that uses Internet technologies (such as HTTP, FTP) to share information within an organization. It is accessible only to authorized users and is not exposed to the external public. Therefore, it is not used to host public servers that need to be accessed from the Internet. The intranet is the opposite of a DMZ in this respect: it is internal and restricted, not a controlled exposure zone.

2) B — Defense in depth.

✓ **Why it is correct:** The correct answer is 'Defense in depth'. Defense in depth is a security strategy that employs multiple layers of security controls, so that if one layer fails, others still protect the system. This includes physical, technical, and administrative controls, such as firewalls, antivirus, multi-factor authentication (MFA), user training, policies, encryption, among others. The goal is not to rely on a single security measure. CompTIA Security+ SY0-701, in the Architecture and Design domain (2.1), describes defense in depth as a core concept. The question describes exactly this: using multiple layers of defense so as not to depend on just one.

✗ **Why the others are wrong:**

- *Zero Trust:* Zero Trust is a security model that assumes no entity, inside or outside the network, is trusted by default. It requires continuous verification of identity and context for each access, following the principle of 'never trust, always verify'. Although Zero Trust may include multiple layers, its main focus is explicit verification and least privilege, not simply the idea of defense layers. The question describes the strategy of multiple layers, which is defense in depth, not the Zero Trust model.
- *Fail-open:* Fail-open is a failure mode in which, when a security system fails, it allows traffic or access to pass, rather than blocking it. This is the opposite of a secure posture, which generally prefers fail-secure (fail-closed). Fail-open is not a layered defense strategy; it is a failure behavior that can be configured on some devices, but does not describe the practice of using multiple

defenses.

- *Security through obscurity*: Security through obscurity is the practice of hiding implementation details or information as a form of protection, for example, using non-standard ports or secret file names. It is considered a weak practice, as it does not resist a determined attacker who discovers the obscurity. It does not refer to multiple layers of defense; on the contrary, it is a single fragile layer. The question describes the combination of various defenses, which is defense in depth.

3) B — Authority + urgency.

✓ **Why it's correct:** The correct alternative is 'Authority + urgency'. Social engineering exploits cognitive biases and psychological principles to manipulate victims. In the scenario, the scammer impersonates IT support, which invokes the principle of authority (the victim tends to obey authority figures). Additionally, he creates a sense of urgency to pressure the victim to act quickly, without thinking critically. The combination of authority and urgency is a classic social engineering tactic, recognized by CompTIA. Therefore, the option 'Authority + urgency' accurately describes the principles exploited.

✗ **Why the others are wrong:**

- *Scarcity*: Scarcity is a persuasion principle that exploits the perception that resources are limited, creating a feeling that the opportunity may be lost if not acted upon immediately. In the scenario, there is no mention of scarce resources or limited offers. The scammer is not offering something in limited quantity, but rather impersonating authority and creating urgency. Therefore, scarcity is not the applicable principle.
- *Social proof*: Social proof is the tendency for people to follow the behavior of others, assuming that actions taken by many are correct. In the described attack, there is no mention of other people doing the same or endorsing the action. The scammer does not use the idea that 'everyone is doing it' to convince the victim. Therefore, social proof is not the principle exploited.
- *Reciprocity*: Reciprocity is the principle that people feel obliged to return a favor or concession. In the scenario, the scammer does not offer anything first and then ask for the password; he simply impersonates support and creates urgency. There is no exchange of favors. Therefore, reciprocity does not apply.

4) D — Implement the corresponding solution: DMZ: zone between internet and internal network — public services reside there.

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.5 (Segmentation & Access Control): DMZ: zone between internet and internal network — public services reside there. A DMZ (demilitarized zone) is a perimeter network that exposes external-facing services to the internet while isolating the internal network, adding a layer of security.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

5) C — Implement the corresponding solution: Allowlist (deny-by-default) is MORE SECURE than denylist....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.5 (Segmentation & Access Control): Allowlist (deny-by-default) is MORE SECURE than denylist. An allowlist explicitly permits only known-good entities and denies everything else by default, reducing the attack surface and preventing unknown threats. A denylist only blocks known-bad entities, leaving the system vulnerable to new or unknown attacks.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) D — Implement the corresponding solution: Microsegmentation: each workload isolated — Zero Trust applied....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.5 (Segmentation & Access Control): Microsegmentation: each workload isolated — Zero Trust applied.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

7) C — Implement the corresponding solution: 'default deny, permit only known' = allowlist..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.5 (Segmentation & Access Control): 'default deny, permit only known' = allowlist. An allowlist (or whitelist) explicitly permits only known and approved entities, denying all others by default, which is a strong access control mechanism.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual

accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) C — Implement the corresponding solution: 'zone between internet and internal network' = DMZ/screened subnet....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.5 (Segmentation & Access Control): 'zone between internet and internal network' = DMZ/screened subnet. A DMZ is a physical or logical subnetwork that exposes external-facing services to an untrusted network, adding an extra layer of security.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) B — Implement the corresponding solution: Scenario: 'public web server resides in a subnet that can talk to the DB but....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.5 (Segmentation & Access Control): Scenario: 'public web server resides in a subnet that can talk to the DB but the internal network cannot reach it' = DMZ/screened subnet. A DMZ (demilitarized zone) or screened subnet is a perimeter network that exposes external-facing services while isolating them from the internal network.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) C — Implement the corresponding solution: DMZ: zone between the internet and internal network — public services live there....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.5 (Segmentation & Access Control): DMZ: zone between the internet and internal network — public services live there.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are

administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.

- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.